

	INFORME PENTEST SOFTWARE **** (WEB)	FECHA DE ELABORACIÓN	NOVIEMBRE /2025
--	--	---------------------------------	----------------------------

Vulnerabilidad XSS Encontrada en el módulo inventario

Introducción:

En este apartado adoptamos la perspectiva de un atacante con conocimientos técnicos en hacking. Aunque muchos usuarios de la plataforma no dominen estas técnicas, no debe subestimarse la posibilidad de que un actor malintencionado con experiencia pueda explotar la vulnerabilidad descrita. Evaluar el hallazgo desde esta postura permite estimar el riesgo real y proponer contramedidas concretas y efectivas. Las organizaciones que aplican principios de “confianza cero” registran sistemáticamente menos incidentes; este informe demuestra cómo dicho enfoque reduce la superficie de ataque y fortalece la resiliencia institucional.

¿Qué es XSS?

El XSS (Cross-Site Scripting) es una de las vulnerabilidades de seguridad web más comunes y peligrosas en la actualidad. Se clasifica consistentemente en el Top 10 de OWASP (Open Web Application Security Project) debido a su frecuencia y potencial destructivo. Esta vulnerabilidad constituye una falla crítica en el modelo de seguridad de la *same-origin policy*, el cual debería proteger a los usuarios de la web.

Más información en: [OWASP Top Ten 2017 | A7:2017-Cross-Site Scripting \(XSS\) | OWASP Foundation](#)

Una de las consecuencias inmediatas es el robo de información sensible como:

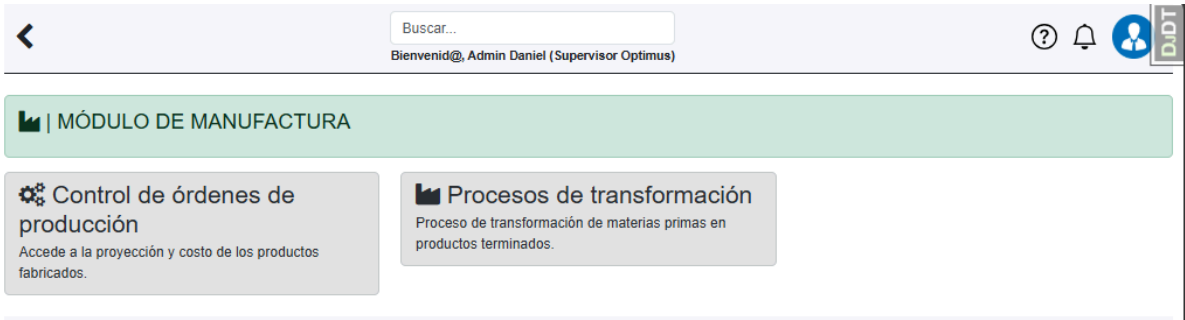
- Cookies de autenticación y de sesión.
- Tokens CSRF y datos de formularios.
- Información personal almacenada en `localStorage`.
- Credenciales introducidas por el usuario.

	INFORME PENTEST SOFTWARE **** (WEB)	FECHA DE ELABORACIÓN	NOVIEMBRE /2025
--	--	---------------------------------	----------------------------

Pasos para la explotación:

Paso 1

Accede al módulo **Manufactura**



Paso 2

Dentro de Manufactura, se ingresa a **Control de órdenes de producción** → **Configurar maquinada** y se selecciona un producto cualquiera.

Navegación

Volver

Crear nueva maquinada

Lista de Maquinadas

Mostrar 10 Entradas

CopiarCsvExcelPDFImprimir

Buscar

#	Creado	Modificado	Producto	Base	Eliminar
1	2025/02/19	2025/11/07	Despiece pieza 1/Despiece pieza 1 x g	100,00000000 kg	
2	2025/01/31	2025/01/31	HIELO/HIELO X g	1,00000000 kg	
3	2025/01/03	2025/01/14	Café con leche/Café con leche X ml	100,00000000 kg	
4	2024/11/14	2025/11/07	prueba 2/prueba 2 X g	150,00000000 kg	
5	2024/11/14	2024/11/14	prueba/prueba X g	105,00000000 kg	
6	2024/10/01	2025/11/06	PAN RELLENO DE CHOCOLATE/PAN RELLENO DE CHOCOLATE X g	132,00000000 kg	
7	2024/10/01	2024/10/01	RELLENO DE CHOCOLATE/RELLENO DE CHOCOLATE x g	100,00000000 kg	

Paso 3

	INFORME PENTEST SOFTWARE **** (WEB)	FECHA DE ELABORACIÓN	NOVIEMBRE /2025
--	--	---------------------------------	----------------------------

En este paso el atacante identifica el nombre del producto seleccionado (por ejemplo, “Corte 1 (Pieza 1)”).

Modificar Fórmula de Maquinada

UsuarioAdmin Daniel Celis

Producto:CONDIMENTO SALCHICHA./IN0015

Cantidad Base:1000.00000000

Kilogramo

Número de unidades a producir:80,00000000

Cantidad total por maquinada en Kg o L.

Al configurar material de empaque, el porcentaje corresponde a cero cuando se trata de unidades; sin embargo, cuando se considera por masa el valor de porcentaje corresponde al peso consumible de una unidad.

Agregar producto

Show50entries

Search:

Eliminar	Producto	Porcentaje	Base de formulación
	Corte 1 (Pieza 1)	-100.00000000 +	☒

Showing 1 to 1 of 1 entries

Previous1Next

Paso 4

Se accede al apartado administrativo correspondiente (por ejemplo, **Programas** → **Inventario**).

MÓDULO INVENTARIO

Parámetros de calidad

Distribución inversión

Inventario

Conoce el estado actual de tu inventario

Ingreso canales

Hace referencia a la recepción de materia prima. Solo aplica para plantas de desposte

Referencia de productos

Crea las referencias del establecimiento

Ajustar inventario

Consolidar inventario

Paso 5

	INFORME PENTEST SOFTWARE **** (WEB)	FECHA DE ELABORACIÓN	NOVIEMBRE /2025
--	--	---------------------------------	----------------------------

Ingresa a “Referencia de productos” y utiliza el buscador para localizar el producto identificado en el paso 3.

Navegación

Volver

Crear nueva referencia

Importar

Presentaciones inactivas

Listado de referencias activas

Mostrar 50 Entradas

CopiarCsvExcelPDFImprimir

BuscarCorte 1 (Pieza 1)

#	Nombre producto	Ref.	Equivalencia	Tipo de ingreso	Precio	Certificado	Criterios de inspección	Historial	Archivos	Eliminar
60	Corte 1 (Pieza 1)	Bolsa	1,00 kg	PT	\$ 0,00	Crear	Crear			
62	Corte 2 (Pieza 1) 1 kg	Bolsa	1,00 kg	PT	\$ 0,00	Crear	Crear			

Mostrando 1 a 2 de 2 Entradas (Filtrado de 240 total entradas)

Anterior

1

Siguiente

Paso 6

Entrar para editar el nombre del producto y cambiarlo por el payload malicioso: `</script><script>alert(1)</script>`Corte 1 (Pieza 1) y se le da a guardar

MODIFICAR REFERENCIA

UsuarioAdmin Daniel Celis

Establecimiento:BPM OPTIMUS S.A.S.

Seleccionar establecimiento

Información

Clasificación del productoProducto terminado

Nombre del producto terminado</script><script>alert(1)</script>Corte 1 (Pieza 1)

ReferenciaBolsa

Unidad de medidaKilogramo

Equivalencia (kg)1,00

Precio0,00

Stock Alerta (kg)100,00

Activo☒

Foto:

Elegir archivoNo se eligió ningún archivo

Seleccionar imagen del producto

Guardar

Volver al listado

Paso 7

	INFORME PENTEST SOFTWARE **** (WEB)	FECHA DE ELABORACIÓN	NOVIEMBRE /2025
--	--	---------------------------------	--------------------

Repetir los pasos 1 a 3:

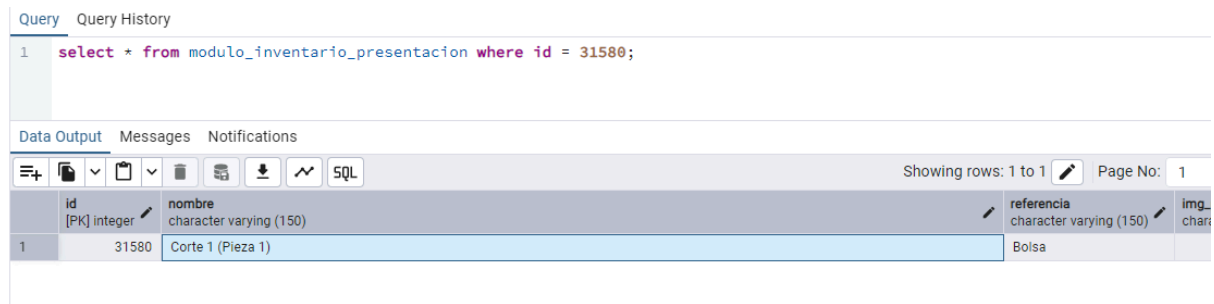
- Ingresar a **Manufactura**.
- Entrar a **Control de órdenes de producción** → **Configurar maquinada** y escoger un producto (esta vez debes asegurarte de seleccionar el mismo en el que identificaste el nombre del producto).

Al acceder, aparecerá lo siguiente:



Esto confirma que, efectivamente, se está ejecutando código JavaScript (JS). Además, se verifica que la inyección queda almacenada en la base de datos (Stored/Persistent XSS), lo que aumenta la peligrosidad de la vulnerabilidad.

Antes:



Después:

	INFORME PENTEST SOFTWARE **** (WEB)	FECHA DE ELABORACIÓN	NOVIEMBRE /2025
--	--	---------------------------------	--------------------

```
Query History
```

```
1 select * from modulo_inventario_presentacion where id = 31580;
```

Data Output Messages Notifications

Showing rows: 1 to 1

	id [PK] integer	nombre character varying (150)	referencia character varying (150)	img_present character varying (100)	fabrica_id integer	masa numeric (8,
1	31580	</script><script>alert("Vulnerable a XSS")</script>Corte 1 (Pieza 1)	Bolsa		1	

	id [PK] integer	nombre character varying (150)	referencia character varying (150)	img_present character varying (100)	fabrica_id integer	masa numeric (8,
1	31580	</script><script>alert("Vulnerable a XSS")</script>Corte 1 (Pieza 1)	Bolsa		1	